

Tenable Vulnerability Management Report

Tenable Vulnerability Management

Tue, 31 Mar 2026 23:10:07 UTC

Table Of Contents

Audits FAILED.....	4
•WN11-00-000135 - A host-based firewall must be installed and enabled on the system.....	5
•WN11-CC-000050 - Hardened UNC Paths must be defined to require mutual authentication and integrity for at least the *\SYSVOL and *\NETLOGON shares.....	7
•WN11-00-000031 - Windows 11 systems must use a BitLocker PIN for pre-boot authentication.....	9
•WN11-SO-000280 - Passwords for enabled local Administrator accounts must be changed at least every 60 days.....	11
•WN11-CC-000039 - Run as different user must be removed from context menus.....	13
•WN11-CC-000070 - Virtualization-based Security must be enabled on Windows 11 with the platform security level configured to Secure Boot or Secure Boot with DMA Protection.....	15
•WN11-CC-000210 - The Microsoft Defender SmartScreen for Explorer must be enabled.....	17
•WN11-PK-000005 - The DoD Root CA certificates must be installed in the Trusted Root Store.....	19
•WN11-PK-000020 - The US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassified systems.....	21
Audits SKIPPED.....	23
Audits PASSED.....	24
•WN11-CC-000063 - Windows 11 systems must use either Group Policy or an approved Mobile Device Management (MDM) product to enforce STIG compliance.....	25
•WN11-00-000170 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB client.....	26
•WN11-00-000085 - Standard local user accounts must not exist on a system in a domain.....	28
•WN11-CC-000037 - Local administrator accounts must have their privileged token filtered to prevent elevated privileges from being used over the network on domain systems.....	29
•WN11-00-000010 - Windows 11 domain-joined systems must have a Trusted Platform Module (TPM) enabled.....	30
•WN11-00-000075 - Only accounts responsible for the backup operations must be members of the Backup Operators group.....	32
•WN11-00-000045 - The Windows 11 system must use an antivirus program.....	33
•WN11-SO-000085 - Caching of logon credentials must be limited.....	35
•WN11-SO-000251 - Windows 11 must use multifactor authentication for local and network access to privileged and nonprivileged accounts.....	36
•WN11-00-000100 - Internet Information System (IIS) or its subcomponents must not be installed on a workstation.....	38
•WN11-UR-000080 - The 'Deny log on as a service' user right on Windows 11 domain-joined workstations must be configured to prevent access from highly privileged domain accounts.....	40
•WN11-RG-000005 - Default permissions for the HKEY_LOCAL_MACHINE registry hive must be maintained.....	42
•DISA_STIG_Microsoft_Windows_11_v2r6.audit from DISA Microsoft Windows 11 STIG v2r6.....	46
•WN11-00-000155 - The Windows PowerShell 2.0 feature must be disabled on the system.....	47
•WN11-00-000005 - Domain-joined systems must use Windows 11 Enterprise Edition 64-bit version.....	49
•WN11-CC-000075 - Credential Guard must be running on Windows 11 domain-joined systems.....	50
•WN11-CC-000130 - Local users on domain-joined computers must not be enumerated.....	52
•WN11-CC-000080 - Virtualization-based protection of code integrity must be enabled.....	54
•WN11-00-000165 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB server.....	56
•WN11-UR-000075 - The 'Deny log on as a batch job' user right on domain-joined workstations must be configured to prevent access from highly privileged domain accounts.....	58
•WN11-00-000095 - Permissions for system files and directories must conform to minimum requirements.....	60
•WN11-CC-000115 - Systems must at least attempt device authentication using certificates.....	62
•WN11-00-000395 - Windows 11 must not have portproxy enabled or in use.....	63

Audits ERROR,INFO,WARNING.....65

- WN11-00-000190 - Orphaned security identifiers (SIDs) must be removed from user rights on Windows 11..... 66
- WN11-00-000250 - Windows 11 nonpersistent VM sessions must not exceed 24 hours..... 67
- WN11-00-000240 - Administrative accounts must not be used with applications that access the internet, such as web browsers, or with potential internet sources, such as email..... 69
- WN11-00-000025 - Windows 11 must employ automated mechanisms to determine the state of system components with regard to flaw remediation using the following frequency: Continuously, where ESS is used; 30 days, for any additional internal network scans not covered by ESS; and annually, for external scans by Computer Network Defense Service Provider (CNDSP)..... 71
- WN11-00-000055 - Alternate operating systems must not be permitted on the same system..... 73
- WN11-00-000130 - Software certificate installation files must be removed from Windows 11..... 74
- WN11-00-000060 - Non-system-created file shares on a system must limit access to groups that require it.....75

Audits FAILED

WN11-00-000135 - A host-based firewall must be installed and enabled on the system.

Info

A firewall provides a line of defense against attack, allowing or blocking inbound and outbound connections based on a set of rules.

Solution

Install and enable a host-based firewall on the system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253281r991589_rule
STIG-ID	WN11-00-000135
SWIFT-CSCV1	2.3
VULN-ID	V-253281

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - Domain:
Remote value: NULL
Policy value: 1

FAILED - PrivateProfile:
Remote value: NULL
Policy value: 1

FAILED - PublicProfile:
Remote value: NULL
Policy value: 1]

WN11-CC-000050 - Hardened UNC Paths must be defined to require mutual authentication and integrity for at least the *\SYSVOL and *\NETLOGON shares.

Info

Additional security requirements are applied to Universal Naming Convention (UNC) paths specified in Hardened UNC paths before allowing access them.

This aids in preventing tampering with or spoofing of connections to these paths.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> Network >> Network Provider >> 'Hardened UNC Paths' to 'Enabled' with at least the following configured in 'Hardened UNC Paths:' (click the 'Show' button to display). Value Name: *\SYSVOL Value: RequireMutualAuthentication=1, RequireIntegrity=1 Value Name: *\NETLOGON Value: RequireMutualAuthentication=1, RequireIntegrity=1

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253362r991589_rule
STIG-ID	WN11-CC-000050
SWIFT-CSCV1	2.3
VULN-ID	V-253362

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - SYSVOL:

```
Remote value: ''
Policy value: 'RequireMutualAuthentication=1,[\s]*RequireIntegrity=1'
-----
FAILED - NETLOGON:
Remote value: ''
Policy value: 'RequireMutualAuthentication=1,[\s]*RequireIntegrity=1']
```


WN11-00-000031 - Windows 11 systems must use a BitLocker PIN for pre-boot authentication.

Info

If data at rest is unencrypted, it is vulnerable to disclosure.

Even if the operating system enforces permissions on data access, an adversary can remove non-volatile memory and read it directly, thereby circumventing operating system controls.

Encrypting the data ensures that confidentiality is protected even when the operating system is not running.

Pre-boot authentication prevents unauthorized users from accessing encrypted drives.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> Windows Components >> BitLocker Drive Encryption >> Operating System Drives 'Require additional authentication at startup' to 'Enabled' with 'Configure TPM Startup PIN:' set to 'Require startup PIN with TPM' or with 'Configure TPM startup key and PIN:' set to 'Require startup key and PIN with TPM'.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.13.16
800-171R3	03.13.08
800-53	SC-28(1)
800-53R5	SC-28(1)
CAT	I
CCI	CCI-002476
CN-L3	8.1.4.7(b)
CN-L3	8.1.4.8(b)
CSF	PR.DS-1
CSF2.0	PR.DS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iv)
HIPAA	164.312(e)(2)(ii)
ISO-27001-2022	A.5.33
ITSG-33	SC-28(1)
PCI-DSSV3.2.1	3.4
PCI-DSSV4.0	3.3.2
PCI-DSSV4.0	3.5.1
QCSC-V1	5.2.2

QCSC-V1	6.2
RULE-ID	SV-253260r958872_rule
STIG-ID	WN11-00-000031
TBA-FIISB	28.1
VULN-ID	V-253260

Assets

sun-disa-stig

```
[The following AND condition has failed:
{
UseAdvancedStartup:
Remote value: NULL
Policy value: 1
}]
```

WN11-SO-000280 - Passwords for enabled local Administrator accounts must be changed at least every 60 days.

Info

The longer a password is in use, the greater the opportunity for someone to gain unauthorized knowledge of the password.

A local Administrator account is not generally used and its password may not be changed as frequently as necessary. Changing the password for enabled Administrator accounts on a regular basis will limit its exposure. Windows LAPS must be used to change the built-in Administrator account password.

Solution

Change the enabled local Administrator account password at least every 60 days. Windows LAPS must be used to change the built-in Administrator account password.

Domain-joined and nondomain-joined systems can configure this to occur more frequently.

LAPS will change the password every 30 days by default. More information is available at: <https://techcommunity.microsoft.com/t5/windows-it-pro-blog/by-popular-demand-windows-laps-available-now/ba-p/3788747>

<https://learn.microsoft.com/en-us/windows-server/identity/laps/laps-overview#windows-laps-supported-platforms-and-azure-ad-laps-preview-status>

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.07d.
800-53	IA-5(1)(d)
800-53R5	IA-5(1)(h)
CAT	II
CCI	CCI-000199
CCI	CCI-004066
CN-L3	7.1.2.7(e)
CN-L3	7.1.3.1(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ISO/IEC-27001	A.9.4.3

ITSG-33	IA-5(1)(d)
NESA	T5.2.3
NIAV2	AM20
NIAV2	AM21
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253476r1051060_rule
STIG-ID	WN11-SO-000280
SWIFT-CSCV1	4.1
TBA-FIISB	26.2.2
VULN-ID	V-253476

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

PASSED - Password last set date for Admin account.:

Remote value: 'PASS: Password age within recommended limits'

Policy value: 'PASS: Password age within recommended limits'

FAILED - LAPS password age configured.:

Remote value: NULL

Policy value: [0..60]

FAILED - LAPS password length configured.:

Remote value: NULL

Policy value: [14..4294967295]

FAILED - LAPS password complexity configured.:

Remote value: NULL

Policy value: 4

FAILED - LAPS name of administrator account enabled.:

Remote value: 'HKLM\Software\Microsoft\Windows\CurrentVersion\Policies
\LAPS_registry_does_not_exist'

Policy value: 'HKLM\Software\Microsoft\Windows\CurrentVersion\Policies\LAPS']

WN11-CC-000039 - Run as different user must be removed from context menus.

Info

The 'Run as different user' selection from context menus allows the use of credentials other than the currently logged on user.

Using privileged credentials in a standard user session can expose those credentials to theft.

Removing this option from context menus helps prevent this from occurring.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> MS Security Guide >> 'Remove 'Run as Different User' from context menus' to 'Enabled'. This policy setting requires the installation of the SecGuide custom templates included with the STIG package.

'SecGuide.admx' and 'SecGuide.adml' must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253359r958478_rule
STIG-ID	WN11-CC-000039

SWIFT-CSCV1

2.3

VULN-ID

V-253359

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - batfile:

Remote value: NULL

Policy value: 4096

FAILED - cmdfile:

Remote value: NULL

Policy value: 4096

FAILED - exefile:

Remote value: NULL

Policy value: 4096

FAILED - mscfile:

Remote value: NULL

Policy value: 4096]

WN11-CC-000070 - Virtualization-based Security must be enabled on Windows 11 with the platform security level configured to Secure Boot or Secure Boot with DMA Protection.

Info

Virtualization-based Security (VBS) provides the platform for the additional security features, Credential Guard and virtualization-based protection of code integrity.

Secure Boot is the minimum security level with DMA protection providing additional memory protection.

DMA Protection requires a CPU that supports input/output memory management unit (IOMMU).

Solution

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop. For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA. Configure the policy value for Computer Configuration >> Administrative Templates >> System >> Device Guard >> 'Turn On virtualization-based Security' to 'Enabled' with 'Secure Boot' or 'Secure Boot and DMA Protection' selected for 'Select Platform Security Level:'. A Microsoft article on Credential Guard system requirement can be found at the following link. <https://technet.microsoft.com/en-us/itpro/windows/keep-secure/credential-guard-requirements>

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253369r991589_rule
STIG-ID	WN11-CC-000070
SWIFT-CSCV1	2.3
VULN-ID	V-253369

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - RequiredSecurityProperties:

Remote value: '0'

Policy value: '2'

FAILED - VirtualizationBasedSecurityStatus:

Remote value: '0'

Policy value: '2']

WN11-CC-000210 - The Microsoft Defender SmartScreen for Explorer must be enabled.

Info

Microsoft Defender SmartScreen helps protect systems from programs downloaded from the internet that may be malicious.

Enabling Microsoft Defender SmartScreen will warn or prevent users from running potentially malicious programs.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> Windows Components >> File Explorer >> 'Configure Windows Defender SmartScreen' to 'Enabled' with 'Warn and prevent bypass' selected. Windows 11 includes duplicate policies for this setting.

It can also be configured under Computer Configuration >> Administrative Templates >> Windows Components >> Windows Defender SmartScreen >> Explorer.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253395r958478_rule
STIG-ID	WN11-CC-000210

SWIFT-CSCV1

2.3

VULN-ID

V-253395

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - EnableSmartScreen:

Remote value: NULL

Policy value: 1

FAILED - ShellSmartScreenLevel:

Remote value: ''

Policy value: 'Block']

WN11-PK-000005 - The DoD Root CA certificates must be installed in the Trusted Root Store.

Info

To ensure secure DoD websites and DoD-signed code are properly validated, the system must trust the DoD Root Certificate Authorities (CAs).

The DoD root certificates will ensure that the trust chain is established for server certificates issued from the DoD CAs.

Solution

Install the DoD Root CA certificates. DoD Root CA 3 DoD Root CA 4 DoD Root CA 5 DoD Root CA 6 The InstallRoot tool is available on Cyber Exchange at <https://cyber.mil/pki-pke/tools-configuration-files>.

PKI can be found at <https://crl.gds.disa.mil/>.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.5.2
800-171R3	03.05.12
800-53	IA-5(2)(a)
800-53R5	IA-5(2)(b)(1)
CAT	II
CCI	CCI-000185
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ISO-27001-2022	A.5.17
ITSG-33	IA-5(2)(a)
NESA	T5.2.3
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253427r958448_rule
STIG-ID	WN11-PK-000005
VULN-ID	V-253427

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - Root CA 4:

WMI_CMD_EXEC_FAILED: Could not execute command

Error: Failed to connect to the 'root\CIMV2' WMI namespace.

FAILED - Root CA 6:

WMI_CMD_EXEC_FAILED: Could not execute command

Error: Failed to connect to the 'root\CIMV2' WMI namespace.

FAILED - Root CA 5:

WMI_CMD_EXEC_FAILED: Could not execute command

Error: Failed to connect to the 'root\CIMV2' WMI namespace.

FAILED - Root CA 3:

WMI_CMD_EXEC_FAILED: Could not execute command

Error: Failed to connect to the 'root\CIMV2' WMI namespace.]

WN11-PK-000020 - The US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificates Store on unclassified systems.

Info

To ensure users do not experience denial of service when performing certificate-based authentication to DOD websites due to the system chaining to a root other than DOD Root CAs, the US DOD CCEB Interoperability Root CA cross-certificates must be installed in the Untrusted Certificate Store.
This requirement only applies to unclassified systems.

Solution

Install the US DOD CCEB Interoperability Root CA cross-certificate on unclassified systems. Issued To - Issued By - Thumbprint 9B74964506C7ED9138070D08D5F8B969866560C8 NotAfter: 7/18/2025 9:56:22 AM Issued To: DOD Root CA 6 Issued By: US DOD CCEB Interoperability Root CA 2 Thumbprint: D471CA32F7A692CE6CBB6196BD3377FE4DBCD106 NotAfter: 7/18/2026 The certificates can be installed using the InstallRoot tool.
The tool and user guide are available on Cyber Exchange at <https://cyber.mil/pki-pke/tools-configuration-files>.
Certificate bundles published by the PKI can be found at <https://crl.gds.disa.mil/>.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.13.15
800-171R3	03.13.15
800-53	SC-23(5)
800-53R5	SC-23(5)
CAT	II
CCI	CCI-002470
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-23
ITSG-33	SC-23a.
NESA	T4.5.1
QCSC-V1	5.2.1
RULE-ID	SV-253430r1081058_rule
STIG-ID	WN11-PK-000020
VULN-ID	V-253430

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

FAILED - Root CA 3:
WMI_CMD_EXEC_FAILED: Could not execute command
Error: Failed to connect to the 'root\CIMV2' WMI namespace.

FAILED - Root CA 6:
WMI_CMD_EXEC_FAILED: Could not execute command

Error: Failed to connect to the 'root\CIMV2' WMI namespace.]

Audits SKIPPED

Audits PASSED

WN11-CC-000063 - Windows 11 systems must use either Group Policy or an approved Mobile Device Management (MDM) product to enforce STIG compliance.

Info

Without Windows 11 systems being managed, devices could be rogue and become targets of an attacker.

Solution

Configure the Windows 11 system to use either Group Policy or an approved MDM product to enforce STIG compliance.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-268318r1135322_rule
STIG-ID	WN11-CC-000063
SWIFT-CSCV1	2.3
VULN-ID	V-268318

Assets

sun-disa-stig

[PASSED]

WN11-00-000170 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB client.

Info

SMBv1 is a legacy protocol that uses the MD5 algorithm as part of SMB.

MD5 is known to be vulnerable to a number of attacks such as collision and preimage attacks as well as not being FIPS compliant. Disabling SMBv1 support may prevent access to file or print sharing resources with systems or devices that only support SMBv1.

File shares and print services hosted on Windows Server 2003 are an example, however Windows Server 2003 is no longer a supported operating system.

Some older network attached devices may only support SMBv1.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> MS Security Guide >>

'Configure SMBv1 client driver' to 'Enabled' with 'Disable driver (recommended)' selected for 'Configure MrxSmb10 driver'. This policy setting requires the installation of the SecGuide custom templates included with the STIG package.

'SecGuide.admx' and 'SecGuide.adml' must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories, respectively. The system must be restarted for the changes to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253288r958478_rule

STIG-ID WN11-00-000170

SWIFT-CSCV1 2.3

VULN-ID V-253288

Assets

sun-disa-stig

[PASSED]

WN11-00-000085 - Standard local user accounts must not exist on a system in a domain.

Info

To minimize potential points of attack, local user accounts, other than built-in accounts and local administrator accounts, must not exist on a workstation in a domain.
Users must log on to workstations in a domain with their domain accounts.

Solution

Limit local user accounts on domain-joined systems.
Remove any unauthorized local accounts.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253272r991589_rule
STIG-ID	WN11-00-000085
SWIFT-CSCV1	2.3
VULN-ID	V-253272

Assets

sun-disa-stig

[PASSED]

WN11-CC-000037 - Local administrator accounts must have their privileged token filtered to prevent elevated privileges from being used over the network on domain systems.

Info

A compromised local administrator account can provide means for an attacker to move laterally between domain systems. With User Account Control enabled, filtering the privileged token for built-in administrator accounts will prevent the elevated privileges of these accounts from being used over the network.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> MS Security Guide >> 'Apply UAC restrictions to local accounts on network logons' to 'Enabled'. This policy setting requires the installation of the SecGuide custom templates included with the STIG package.

'SecGuide.admx' and 'SecGuide.adml' must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories respectively.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-53	SC-3
800-53R5	SC-3
CAT	II
CCI	CCI-001084
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-3
ITSG-33	SC-3a.
NESA	T3.4.1
NESA	T4.3.1
NESA	T4.3.2
RULE-ID	SV-253357r958518_rule
STIG-ID	WN11-CC-000037
VULN-ID	V-253357

Assets

sun-disa-stig

[PASSED]

WN11-00-000010 - Windows 11 domain-joined systems must have a Trusted Platform Module (TPM) enabled.

Info

Credential Guard uses virtualization-based security to protect information that could be used in credential theft attacks if compromised.

There are a number of system requirements that must be met in order for Credential Guard to be configured and enabled properly.

Without a TPM enabled and ready for use, Credential Guard keys are stored in a less secure method using software.

Solution

For standalone systems, this is NA. Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop. For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA. Ensure domain-joined systems must have a TPM that is configured for use.

(Versions 2.0 support Credential Guard.) The TPM must be enabled in the firmware. Run 'tpm.msc' for configuration options in Windows.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.13.8
800-171R3	03.13.08
800-53	SC-8(1)
800-53R5	SC-8(1)
CAT	II
CCI	CCI-002421
CN-L3	8.1.2.2(a)
CN-L3	8.1.2.2(b)
CN-L3	8.1.4.7(a)
CN-L3	8.1.4.8(a)
CN-L3	8.2.4.5(c)
CN-L3	8.2.4.5(d)
CN-L3	8.5.2.2
CSF	PR.DS-2
CSF	PR.DS-5
CSF2.0	PR.DS-02
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)

HIPAA	164.312(e)(1)
HIPAA	164.312(e)(2)(i)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.14
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.10.1.1
ISO/IEC-27001	A.13.2.3
ITSG-33	SC-8(1)
NESA	T7.4.1
NIAV2	NS5d
NIAV2	NS6b
PCI-DSSV3.2.1	2.3
PCI-DSSV3.2.1	4.1
PCI-DSSV4.0	2.2.7
PCI-DSSV4.0	4.2.1
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-253255r1117271_rule
STIG-ID	WN11-00-000010
SWIFT-CSCV1	2.1
TBA-FIISB	29.1
VULN-ID	V-253255

Assets

sun-disa-stig

[PASSED]

WN11-00-000075 - Only accounts responsible for the backup operations must be members of the Backup Operators group.

Info

Backup Operators are able to read and write to any file in the system, regardless of the rights assigned to it. Backup and restore rights permit users to circumvent the file access restrictions present on NTFS disk drives for backup and restore purposes.

Members of the Backup Operators group must have separate logon accounts for performing backup duties.

Solution

Create separate accounts for backup operations for users with this privilege.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253270r991589_rule
STIG-ID	WN11-00-000075
SWIFT-CSCV1	2.3
VULN-ID	V-253270

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

PASSED - Check if no accounts are members of the Backup Operators group.:
Remote value: 'PASS: No accounts are part of the Backup Operators group.'
Policy value: 'PASS: No accounts are part of the Backup Operators group.']

WN11-00-000045 - The Windows 11 system must use an antivirus program.

Info

Malicious software can establish a base on individual desktops and servers. Employing an automated mechanism to detect this type of software will aid in elimination of the software from the operating system.

Solution

Install Microsoft Defender Antivirus or a third-party antivirus solution.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253264r991589_rule
STIG-ID	WN11-00-000045
SWIFT-CSCV1	2.3
VULN-ID	V-253264

Assets

sun-disa-stig

[One of the following must pass to satisfy this requirement:

```
-----
PASSED - Microsoft Defender Antivirus is installed:
Remote value: 'Status      : Running
DisplayName  : Microsoft Defender Antivirus Network Inspection Service
RunspaceId   : c6a3158e-a15b-4b4b-b67c-d9defa587b93
Status       : Running
DisplayName  : Microsoft Defender Antivirus Service
```

RunspaceId : c6a3158e-a15b-4b4b-b67c-d9defa587b93
PASS'
Policy value: '^PASS\$'

FAILED - Symantec Antivirus is installed:
Remote value: 'FAIL - Symantec Antivirus not found'
Policy value: '^PASS\$'

FAILED - McAfee Antivirus is installed:
Remote value: 'FAIL - McAfee Antivirus not found'
Policy value: '^PASS\$']

WN11-SO-000085 - Caching of logon credentials must be limited.

Info

The default Windows configuration caches the last logon credentials for users who log on interactively to a system. This feature is provided for system availability reasons, such as the user's machine being disconnected from the network or domain controllers being unavailable.

Even though the credential cache is well-protected, if a system is attacked, an unauthorized individual may isolate the password to a domain user account using a password-cracking program and gain access to the domain.

Solution

This is the default configuration for this setting (10 logons to cache). Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> Security Options >> 'Interactive logon: Number of previous logons to cache (in case domain controller is not available)' to '10' logons or less. This setting only applies to domain-joined systems, however, it is configured by default on all systems.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	III
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253447r991589_rule
STIG-ID	WN11-SO-000085
SWIFT-CSCV1	2.3
VULN-ID	V-253447

Assets

sun-disa-stig

[PASSED]

WN11-SO-000251 - Windows 11 must use multifactor authentication for local and network access to privileged and nonprivileged accounts.

Info

Without the use of multifactor authentication, the ease of access to privileged and nonprivileged functions is greatly increased. All domain accounts must be enabled for multifactor authentication with the exception of local emergency accounts. Multifactor authentication requires using two or more factors to achieve authentication. Factors include: 1) Something a user knows (e.g., password/PIN); 2) Something a user has (e.g., cryptographic identification device, token); and 3) Something a user is (e.g., biometric). A privileged account is defined as an information system account with authorizations of a privileged user. Network access is defined as access to an information system by a user (or a process acting on behalf of a user) communicating through a network (e.g., local area network, wide area network, or the internet). Local access is defined as access to an organizational information system by a user (or process acting on behalf of a user) communicating through a direct connection without the use of a network. The DoD CAC with DoD-approved PKI is an example of multifactor authentication. Satisfies: SRG-OS-000106-GPOS-00053, SRG-OS-000107-GPOS-00054, SRG-OS-000108-GPOS-00055

Solution

For nondomain joined systems, configuring Windows Hello for sign-on options would be suggested based on the organization's needs and capabilities.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.5.3
800-171R3	03.05.03
800-53	IA-2(1)
800-53R5	IA-2(1)
CAT	II
CCI	CCI-000765
CN-L3	7.1.2.7(b)
CSF	PR.AC-1
CSF2.0	PR.AA-01
CSF2.0	PR.AA-03
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(i)
HIPAA	164.312(d)
ISO-27001-2022	A.5.16
ITSG-33	IA-2(1)
NESA	T5.4.2
NIAV2	AM36
NIAV2	VL3c

QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253470r1106510_rule
STIG-ID	WN11-SO-000251
SWIFT-CSCV1	1.2
TBA-FIISB	35.1
TBA-FIISB	36.1
VULN-ID	V-253470

Assets

sun-disa-stig

[PASSED]

WN11-00-000100 - Internet Information System (IIS) or its subcomponents must not be installed on a workstation.

Info

IIS is not installed by default.

Installation of Internet Information System (IIS) may allow unauthorized internet services to be hosted.

Websites must only be hosted on servers that have been designed for that purpose and can be adequately secured.

NOTE: Nessus has provided the target output to assist in reviewing the benchmark to ensure target compliance.

Solution

Uninstall 'Internet Information Services' or 'Internet Information Services Hostable Web Core' from the system.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	I
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253275r958478_rule
STIG-ID	WN11-00-000100
SWIFT-CSCV1	2.3

Assets**sun-disa-stig**

[All of the following must pass to satisfy this requirement:

PASSED - IIS-WebServer:

Remote value: ''

Policy value: '^Manual Review Required\$'

PASSED - IIS-HostableWebCore:

Remote value: ''

Policy value: '^Manual Review Required\$']

WN11-UR-000080 - The 'Deny log on as a service' user right on Windows 11 domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

Info

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities. The 'Deny log on as a service' right defines accounts that are denied log on as a service. In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks which could lead to the compromise of an entire domain. Incorrect configurations could prevent services from starting and result in a DoS.

Solution

This requirement is applicable to domain-joined systems, for standalone systems this is NA. Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> User Rights Assignment >> 'Deny log on as a service' to include the following: Domain Systems Only: Enterprise Admins Group Domain Admins Group

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15

ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253493r1137691_rule
STIG-ID	WN11-UR-000080
TBA-FIISB	31.1
VULN-ID	V-253493

Assets

sun-disa-stig

[PASSED]

WN11-RG-000005 - Default permissions for the HKEY_LOCAL_MACHINE registry hive must be maintained.

Info

The registry is integral to the function, security, and stability of the Windows system. Changing the system's registry permissions allows the possibility of unauthorized and anonymous modification to the operating system.

Solution

Maintain the default permissions for the HKEY_LOCAL_MACHINE registry hive. The default permissions of the higher level keys are noted below. HKEY_LOCAL_MACHINE\SECURITY Type - 'Allow' for all Inherited from - 'None' for all Principal - Access - Applies to SYSTEM - Full Control - This key and subkeys Administrators - Special - This key and subkeys HKEY_LOCAL_MACHINE\SOFTWARE Type - 'Allow' for all Inherited from - 'None' for all Principal - Access - Applies to Users - Read - This key and subkeys Administrators - Full Control - This key and subkeys SYSTEM - Full Control - This key and subkeys CREATOR OWNER - Full Control - This key and subkeys ALL APPLICATION PACKAGES - Read - This key and subkeys HKEY_LOCAL_MACHINE\SYSTEM Type - 'Allow' for all Inherited from - 'None' for all Principal - Access - Applies to Users - Read - This key and subkeys Administrators - Full Control - This key and subkeys SYSTEM - Full Control - This key and subkeys CREATOR OWNER - Full Control - This key and subkeys ALL APPLICATION PACKAGES - Read - This key and subkeys Microsoft has also given read permission to the SOFTWARE and SYSTEM registry keys in later versions of Windows 11 to the following SID. S-1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.1.7
800-171R3	03.01.07a.
800-53	AC-6(10)
800-53R5	AC-6(10)
CAT	II
CCI	CCI-002235
CN-L3	7.1.3.2(b)
CN-L3	7.1.3.2(g)
CN-L3	8.1.4.2(d)
CN-L3	8.1.10.6(a)
CSF	PR.AC-4
CSF2.0	PR.AA-05
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.8.2
ISO-27001-2022	A.8.18

ITSG-33	AC-6
NESA	T5.1.1
NESA	T5.2.2
NESA	T5.4.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.3
NIAV2	AM1
NIAV2	AM23f
NIAV2	SS13c
NIAV2	SS15c
PCI-DSSV3.2.1	7.1.2
PCI-DSSV4.0	7.2.1
PCI-DSSV4.0	7.2.2
QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-253431r958726_rule
STIG-ID	WN11-RG-000005
SWIFT-CSCV1	5.1
TBA-FIISB	31.4.2
TBA-FIISB	31.4.3
VULN-ID	V-253431

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

PASSED - HKEY_LOCAL_MACHINE\SECURITY:

Remote value:

administrators:

+ Apply To: 'this key and subkeys'

|- Inheritance: 'not inherited'

|- Allow: 'read control' | 'write dac'

system:

+ Apply To: 'this key and subkeys'

|- Inheritance: 'not inherited'

|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' | 'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'

Policy value:

administrators:

```

+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'read control' | 'write dac'
system:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
-----
PASSED - HKEY_LOCAL_MACHINE\SOFTWARE:
Remote value:
1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
administrators:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
all application packages:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
creator owner:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
system:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
users:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
Policy value:
1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
administrators:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
all application packages:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
creator owner:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
system:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
users:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
-----
PASSED - HKEY_LOCAL_MACHINE\SYSTEM:
Remote value:
1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
administrators:
+ Apply To: 'this key and subkeys'

```

```

|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
all application packages:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
creator owner:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
system:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
users:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
Policy value:
1-15-3-1024-1065365936-1281604716-3511738428-1654721687-432734479-3232135806-4053264122-3456934681:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
administrators:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
all application packages:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control'
creator owner:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
system:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'create link' | 'create subkey' | 'delete' | 'enumerate subkeys' | 'full control' |
'notify' | 'query value' | 'read control' | 'set value' | 'write dac' | 'write owner'
users:
+ Apply To: 'this key and subkeys'
|- Inheritance: 'not inherited'
|- Allow: 'enumerate subkeys' | 'notify' | 'query value' | 'read control']

```

DISA_STIG_Microsoft_Windows_11_v2r6.audit from DISA Microsoft Windows 11 STIG v2r6

Info

Solution

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

PASSED - Windows 11 is installed:

Remote value: '26200'

Policy value: '2[26][0-9]{3}'

PASSED - Windows 11 installation type:

Remote value: 'Client'

Policy value: 'Client']

WN11-00-000155 - The Windows PowerShell 2.0 feature must be disabled on the system.

Info

Windows PowerShell 5.0 added advanced logging features, which can provide additional detail when malware has been run on a system.

Disabling the Windows PowerShell 2.0 mitigates against a downgrade attack that evades the Windows PowerShell 5.0 script block logging feature.

Solution

Disable 'Windows PowerShell 2.0' on the system. Run 'Windows PowerShell' with elevated privileges (run as administrator). Enter the following: `Disable-WindowsOptionalFeature -Online -FeatureName MicrosoftWindowsPowerShellV2Root` This command must disable both 'MicrosoftWindowsPowerShellV2Root' and 'MicrosoftWindowsPowerShellV2', which correspond to 'Windows PowerShell 2.0' and 'Windows PowerShell 2.0 Engine' respectively in 'Turn Windows features on or off'. Alternately: Search for 'Features'. Select 'Turn Windows features on or off'. De-select 'Windows PowerShell 2.0'.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253285r1153425_rule

STIG-ID WN11-00-000155

SWIFT-CSCV1 2.3

VULN-ID V-253285

Assets

sun-disa-stig

[PASSED]

WN11-00-000005 - Domain-joined systems must use Windows 11 Enterprise Edition 64-bit version.

Info

Features such as Credential Guard use virtualization-based security to protect information that could be used in credential theft attacks if compromised.

There are a number of system requirements that must be met in order for Credential Guard to be configured and enabled properly.

Virtualization-based security and Credential Guard are only available with Windows 11 Enterprise 64-bit version.

Solution

Use Windows 11 Enterprise 64-bit version for domain-joined systems.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253254r991589_rule
STIG-ID	WN11-00-000005
SWIFT-CSCV1	2.3
VULN-ID	V-253254

Assets

sun-disa-stig

[PASSED]

WN11-CC-000075 - Credential Guard must be running on Windows 11 domain-joined systems.

Info

Credential Guard uses virtualization-based security to protect information that could be used in credential theft attacks if compromised.

This authentication information, which was stored in the Local Security Authority (LSA) in previous versions of Windows, is isolated from the rest of operating system and can only be accessed by privileged system software.

Solution

Virtualization-based security, including Credential Guard, currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop. For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA. For VDIs with persistent desktops, this may be downgraded to a CAT II only where administrators have specific tokens for the VDI.

Administrator accounts on virtual desktops must only be used on systems in the VDI; they may not have administrative privileges on any other systems such as servers and physical workstations. Configure the policy value for Computer Configuration >> Administrative Templates >> System >> Device Guard >> 'Turn On virtualization-based Security' to 'Enabled' with 'Enabled with UEFI lock' selected for 'Credential Guard Configuration:'. A Microsoft TechNet article on Credential Guard, including system requirement details, can be found at the following link: <https://docs.microsoft.com/en-us/windows/access-protection/credential-guard/credential-guard>

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253370r991589_rule
STIG-ID	WN11-CC-000075
SWIFT-CSCV1	2.3

VULN-ID

V-253370

Assets

sun-disa-stig

[PASSED]

WN11-CC-000130 - Local users on domain-joined computers must not be enumerated.

Info

The username is one part of logon credentials that could be used to gain access to a system. Preventing the enumeration of users limits this information to authorized personnel.

Solution

This requirement is applicable to domain-joined systems, for standalone systems this is NA. Configure the policy value for Computer Configuration >> Administrative Templates >> System >> Logon >> 'Enumerate local users on domain-joined computers' to 'Disabled'.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253379r958478_rule
STIG-ID	WN11-CC-000130
SWIFT-CSCV1	2.3
VULN-ID	V-253379

Assets

sun-disa-stig

[PASSED]

WN11-CC-000080 - Virtualization-based protection of code integrity must be enabled.

Info

Virtualization-based protection of code integrity enforces kernel mode memory protections as well as protecting Code Integrity validation paths.

This isolates the processes from the rest of the operating system and can only be accessed by privileged system software.

Solution

Virtualization-based security currently cannot be implemented in virtual desktop implementations (VDI) due to specific supporting requirements including a TPM, UEFI with Secure Boot, and the capability to run the Hyper-V feature within the virtual desktop. For VDIs where the virtual desktop instance is deleted or refreshed upon logoff, this is NA. Configure the policy value for Computer Configuration >> Administrative Templates >> System >> Device Guard >> 'Turn On virtualization-based Security' to 'Enabled' with 'Enabled with UEFI lock' or 'Enabled without lock' selected for 'virtualization-based Protection of Code Integrity.'. 'Enabled with UEFI lock' is preferred as more secure, however it cannot be turned off remotely through a group policy change if there is an issue. 'Enabled without lock' will allow this to be turned off remotely while testing for issues.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253371r991589_rule
STIG-ID	WN11-CC-000080
SWIFT-CSCV1	2.3
VULN-ID	V-253371

Assets

sun-disa-stig

[PASSED]

WN11-00-000165 - The Server Message Block (SMB) v1 protocol must be disabled on the SMB server.

Info

SMBv1 is a legacy protocol that uses the MD5 algorithm as part of SMB.

MD5 is known to be vulnerable to a number of attacks such as collision and preimage attacks as well as not being FIPS compliant. Disabling SMBv1 support may prevent access to file or print sharing resources with systems or devices that only support SMBv1.

File shares and print services hosted on Windows Server 2003 are an example, however Windows Server 2003 is no longer a supported operating system.

Some older network attached devices may only support SMBv1.

Solution

Configure the policy value for Computer Configuration >> Administrative Templates >> MS Security Guide >>

'Configure SMBv1 Server' to 'Disabled'. This policy setting requires the installation of the SecGuide custom templates included with the STIG package.

'SecGuide.admx' and 'SecGuide.adml' must be copied to the \Windows\PolicyDefinitions and \Windows\PolicyDefinitions\en-US directories, respectively. The system must be restarted for the change to take effect.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-253287r958478_rule

STIG-ID WN11-00-000165

SWIFT-CSCV1 2.3

VULN-ID V-253287

Assets

sun-disa-stig

[PASSED]

WN11-UR-000075 - The 'Deny log on as a batch job' user right on domain-joined workstations must be configured to prevent access from highly privileged domain accounts.

Info

Inappropriate granting of user rights can provide system, administrative, and other high-level capabilities. The 'Deny log on as a batch job' right defines accounts that are prevented from logging on to the system as a batch job, such as Task Scheduler. In an Active Directory Domain, denying logons to the Enterprise Admins and Domain Admins groups on lower trust systems helps mitigate the risk of privilege escalation from credential theft attacks which could lead to the compromise of an entire domain.

Solution

This requirement is applicable to domain-joined systems, for standalone systems this is NA. Configure the policy value for Computer Configuration >> Windows Settings >> Security Settings >> Local Policies >> User Rights Assignment >> 'Deny log on as a batch job' to include the following: Domain Systems Only: Enterprise Admin Group Domain Admin Group

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3
800-53R5	AC-3
CAT	II
CCI	CCI-000213
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15

ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18
ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253492r1137691_rule
STIG-ID	WN11-UR-000075
TBA-FIISB	31.1
VULN-ID	V-253492

Assets

sun-disa-stig

[PASSED]

WN11-00-000095 - Permissions for system files and directories must conform to minimum requirements.

Info

Changing the system's file and directory permissions allows the possibility of unauthorized and anonymous modification to the operating system and installed applications.

Solution

Maintain the default file system permissions and configure the Security Option: 'Network access: Let everyone permissions apply to anonymous users' to 'Disabled' (WN11-SO-000160).

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.1.1
800-171R3	03.01.02
800-53	AC-3(4)
800-53R5	AC-3(4)
CAT	II
CCI	CCI-002165
CN-L3	8.1.4.2(f)
CN-L3	8.1.4.11(b)
CN-L3	8.1.10.2(c)
CN-L3	8.5.3.1
CN-L3	8.5.4.1(a)
CSF	PR.AC-4
CSF	PR.PT-3
CSF2.0	PR.AA-05
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(1)
ISO-27001-2022	A.5.15
ISO-27001-2022	A.5.33
ISO-27001-2022	A.8.3
ISO-27001-2022	A.8.18

ISO-27001-2022	A.8.20
ISO/IEC-27001	A.9.4.1
ISO/IEC-27001	A.9.4.5
ITSG-33	AC-3(4)
NESA	T4.2.1
NESA	T5.4.4
NESA	T5.4.5
NESA	T5.5.4
NESA	T5.6.1
NESA	T7.5.2
NESA	T7.5.3
NIAV2	AM3
NIAV2	SS29
QCSC-V1	3.2
QCSC-V1	5.2.2
QCSC-V1	13.2
RULE-ID	SV-253274r1016661_rule
STIG-ID	WN11-00-000095
TBA-FIISB	31.1
VULN-ID	V-253274

Assets

sun-disa-stig

[PASSED]

WN11-CC-000115 - Systems must at least attempt device authentication using certificates.

Info

Using certificates to authenticate devices to the domain provides increased security over passwords. By default systems will attempt to authenticate using certificates and fall back to passwords if the domain controller does not support certificates for devices. This may also be configured to always use certificates for device authentication.

Solution

This requirement is applicable to domain-joined systems, for standalone systems this is NA. The default behavior for 'Support device authentication using certificate' is 'Automatic'. To correct this, configured the policy value for Computer Configuration >> Administrative Templates >> System >> Kerberos >> 'Support device authentication using certificate' to 'Not Configured or 'Enabled' with either option selected in 'Device authentication behavior using certificate:'.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253377r991589_rule
STIG-ID	WN11-CC-000115
SWIFT-CSCV1	2.3
VULN-ID	V-253377

Assets

sun-disa-stig

[PASSED]

WN11-00-000395 - Windows 11 must not have portproxy enabled or in use.

Info

Having portproxy enabled or configured in Windows 10 could allow a man-in-the-middle attack.

Solution

Contact the Administrator to run 'netsh interface portproxy delete' with elevation.
Remove any enabled portproxies that may be configured.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.6
800-171	3.4.7
800-171R3	03.04.06a.
800-53	CM-7a.
800-53R5	CM-7a.
CAT	II
CCI	CCI-000381
CN-L3	7.1.3.5(c)
CN-L3	8.1.4.4(a)
CSF	PR.IP-1
CSF	PR.PT-3
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	CM-7a.
NIAV2	SS15a
PCI-DSSV3.2.1	2.2.1
PCI-DSSV4.0	2.2.3
QCSC-V1	3.2
RULE-ID	SV-257592r991589_rule
STIG-ID	WN11-00-000395
SWIFT-CSCV1	2.3
VULN-ID	V-257592

Assets

sun-disa-stig

[All of the following must pass to satisfy this requirement:

PASSED - netsh:

Remote value: 'Not found'

Policy value: 'Not found'

PASSED - PortProxy:

Remote value: 'HKLM\SYSTEM\CurrentControlSet\Services\PortProxy

\v4tov4\tcp_registry_does_not_exist'

Policy value: 'HKLM\SYSTEM\CurrentControlSet\Services\PortProxy\v4tov4\tcp']

Audits ERROR,INFO,WARNING

WN11-00-000190 - Orphaned security identifiers (SIDs) must be removed from user rights on Windows 11.

Info

Accounts or groups given rights on a system may show up as unresolved SIDs for various reasons including deletion of the accounts or groups.

If the account or group objects are reanimated, there is a potential they may still have rights no longer intended.

Valid domain accounts or groups may also show up as unresolved SIDs if a connection to the domain cannot be established for some reason. NOTE: Nessus has not performed this check.

Please review the benchmark to ensure target compliance.

Solution

Remove any unresolved SIDs found in User Rights assignments and determined to not be for currently valid accounts or groups by removing the accounts or groups from the appropriate group policy.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253290r991589_rule
STIG-ID	WN11-00-000190
SWIFT-CSCV1	2.3
VULN-ID	V-253290

Assets

sun-disa-stig

[]

WN11-00-000250 - Windows 11 nonpersistent VM sessions must not exceed 24 hours.

Info

For virtual desktop implementations (VDIs) where the virtual desktop instance is deleted or refreshed upon logoff, the organization must enforce that sessions be terminated within 24 hours.

This would ensure any data stored on the VM that is not encrypted or covered by Credential Guard is deleted. NOTE: Nessus has not performed this check.

Please review the benchmark to ensure target compliance.

Solution

Set nonpersistent VM sessions to not exceed 24 hours.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.13.16
800-171R3	03.13.08
800-53	SC-28
800-53R5	SC-28
CAT	II
CCI	CCI-001199
CN-L3	8.1.4.7(b)
CN-L3	8.1.4.8(b)
CSF	PR.DS-1
CSF2.0	PR.DS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.a
GDPR	32.1.b
HIPAA	164.306(a)(1)
HIPAA	164.312(a)(2)(iv)
HIPAA	164.312(e)(2)(ii)
ISO-27001-2022	A.5.10
ISO-27001-2022	A.5.33
ITSG-33	SC-28
ITSG-33	SC-28a.
PCI-DSSV3.2.1	3.4
PCI-DSSV4.0	3.3.2
PCI-DSSV4.0	3.5.1

QCSC-V1	5.2.2
QCSC-V1	6.2
RULE-ID	SV-253295r958552_rule
STIG-ID	WN11-00-000250
VULN-ID	V-253295

Assets

sun-disa-stig

[]

WN11-00-000240 - Administrative accounts must not be used with applications that access the internet, such as web browsers, or with potential internet sources, such as email.

Info

Using applications that access the internet or have potential internet sources using administrative privileges exposes a system to compromise.

If a flaw in an application is exploited while running as a privileged user, the entire system could be compromised. Web browsers and email are common attack vectors for introducing malicious code and must not be run with an administrative account. Since administrative accounts may generally change or work around technical restrictions for running a web browser or other applications, it is essential that policy requires administrative accounts to not access the internet or use applications, such as email. The policy must define specific exceptions for local service administration.

These exceptions may include HTTP(S)-based tools that are used for the administration of the local system, services, or attached devices. Technical means such as application allowlisting can be used to enforce the policy to ensure compliance. NOTE: Nessus has not performed this check.

Please review the benchmark to ensure target compliance.

Solution

Establish and enforce a policy that prohibits administrative accounts from using applications that access the internet, such as web browsers, or with potential internet sources, such as email.

Define specific exceptions for local service administration.

These exceptions may include HTTP(S)-based tools that are used for the administration of the local system, services, or attached devices. Implement technical measures where feasible such as removal of applications or use of application allowlisting to restrict the use of applications that can access the internet.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	I
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253294r991589_rule

STIG-ID WN11-00-000240

SWIFT-CSCV1 2.3

VULN-ID V-253294

Assets

sun-disa-stig

[]

WN11-00-000025 - Windows 11 must employ automated mechanisms to determine the state of system components with regard to flaw remediation using the following frequency: Continuously, where ESS is used; 30 days, for any additional internal network scans not covered by ESS; and annually, for external scans by Computer Network Defense Service Provider (CNDSP).

Info

An approved tool for continuous network scanning must be installed and configured to run. Without the use of automated mechanisms to scan for security flaws on a continuous and/or periodic basis, the operating system or other system components may remain vulnerable to the exploits presented by undetected software flaws. To support this requirement, the operating system may have an integrated solution incorporating continuous scanning using ESS and periodic scanning using other tools, as specified in the requirement. NOTE: Nessus has not performed this check. Please review the benchmark to ensure target compliance.

Solution

Install DOD-approved ESS software and ensure it is operating continuously.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253258r1000099_rule
STIG-ID	WN11-00-000025
SWIFT-CSCV1	2.3
VULN-ID	V-253258

Assets

sun-disa-stig

[]

WN11-00-000055 - Alternate operating systems must not be permitted on the same system.

Info

Allowing other operating systems to run on a secure system may allow security to be circumvented. NOTE: Nessus has not performed this check.
Please review the benchmark to ensure target compliance.

Solution

Ensure Windows 11 is the only operating system on a device.
Remove alternate operating systems.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253266r991589_rule
STIG-ID	WN11-00-000055
SWIFT-CSCV1	2.3
VULN-ID	V-253266

Assets

sun-disa-stig

[]

WN11-00-000130 - Software certificate installation files must be removed from Windows 11.

Info

Use of software certificates and their accompanying installation files for end users to access resources is less secure than the use of hardware-based certificates. NOTE: Nessus has not performed this check. Please review the benchmark to ensure target compliance.

Solution

Remove any certificate installation files (*.p12 and *.pfx) found on a system. Note: This does not apply to server-based applications that have a requirement for .p12 certificate files (e.g., Oracle Wallet Manager) or Adobe PreFlight certificate files.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.4.2
800-171R3	03.04.02a.
800-53	CM-6b.
800-53R5	CM-6b.
CAT	II
CCI	CCI-000366
CN-L3	8.1.10.6(d)
CSF	PR.IP-1
CSF2.0	DE.CM-09
CSF2.0	PR.PS-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ISO-27001-2022	A.8.9
ITSG-33	CM-6b.
NESA	T3.2.1
RULE-ID	SV-253280r991589_rule
STIG-ID	WN11-00-000130
SWIFT-CSCV1	2.3
VULN-ID	V-253280

Assets

sun-disa-stig

[]

WN11-00-000060 - Non-system-created file shares on a system must limit access to groups that require it.

Info

Shares which provide network access, must not exist on a workstation except for system-created administrative shares, and could potentially expose sensitive information.

If a share is necessary, share permissions, as well as NTFS permissions, must be reconfigured to give the minimum access to those accounts that require it. NOTE: Nessus has not performed this check.

Please review the benchmark to ensure target compliance.

Solution

If a non-system-created share is required on a system, configure the share and NTFS permissions to limit access to the specific groups or accounts that require it. Remove any unnecessary non-system-created shares.

See Also

https://dl.dod.cyber.mil/wp-content/uploads/stigs/zip/U_MS_Windows_11_V2R6_STIG.zip

References

800-171	3.13.4
800-171R3	03.13.04
800-53	SC-4
800-53R5	SC-4
CAT	II
CCI	CCI-001090
CSF2.0	PR.DS-01
CSF2.0	PR.DS-02
CSF2.0	PR.DS-10
CSF2.0	PR.IR-01
DISA_BENCHMARK	Microsoft_Windows_11_STIG
GDPR	32.1.b
HIPAA	164.306(a)(1)
ITSG-33	SC-4
ITSG-33	SC-4a.
RULE-ID	SV-253267r1137695_rule
STIG-ID	WN11-00-000060
VULN-ID	V-253267

Assets

sun-disa-stig

[]